



---

# Operationalising Expectation Entropy for Password Strength Evaluation

---

Research Report



*Author:* FATIMA ZAKIR

# 1. Introduction

Password strength estimation is a constant challenge in cybersecurity, due to the gap between theoretical entropy measures and actual password creation. Classical combinatorial entropy assumes random selection from a character pool uniformly; an unrealistic assumption at that.

Recent research has proposed alternative entropy-based metrics to better capture per-password strength. In particular, Expectation Entropy as a Password Strength Metric [1] introduces Expectation Entropy, a metric designed to show the uncertainty of individual passwords by capturing the composition of characters.

This project implements an interactive password strength estimation tool inspired by the idea of Expectation Entropy. Rather than reproducing the paper's formulation directly, the tool focuses on the paper's main insight and demonstrates how structurally informed entropy estimates can be interpreted through estimated offline brute-force cracking time.

## 2. Related Work

Expectation Entropy addresses shortcomings in classical entropy-based password strength estimation [1]. The authors show that passwords with similar length and characters may exhibit significantly different strength values when evaluated using Expectation Entropy.

Recent work on password security emphasizes the importance of attacker-aware evaluation, where password strength metrics are interpreted in the context of attack models rather than abstract entropy values alone [2]. Similarly, modern password guidance discourages reliance on single numerical strength scores without context [3].

These trends motivate the need for tools that not only compute password strength metrics but also explain their implications in attacker-centric terms.

## 3. Motivation

Although Expectation Entropy provides a more nuanced per-password metric, the original paper does not:

- Provide a simple and reproducible implementation for practitioners
- Map entropy bits to concrete offline cracking timelines

As noted, practitioners benefit more from interpretable attacker-centric feedback than from abstract numerical scores alone.

This project addresses this gap by adopting the structural idea of Expectation Entropy and implementing its core using a Shannon entropy-based formulation that produces entropy values in bits. This enables educational crack-time estimation under offline attack assumptions.

## 4. Methodology

This section describes the mathematical formulation implemented in the password strength estimation tool and explains how it is inspired by the intuition of Expectation Entropy while differing from the original formulation in [1].

### 4.1 Character Class Modelling

Each input password  $P$  of length  $L$  is analysed by grouping its characters into four disjoint character classes:

- Lowercase letters ( $\mathcal{L}$ ), size 26

- Uppercase letters ( $\mathcal{U}$ ), size 26
- Digits ( $\mathcal{D}$ ), size 10
- Symbols ( $\mathcal{S}$ ), size 32

Let  $n_i$  denote the number of characters in the password belonging to class  $i$ . This step directly follows the modelling introduced in Expectation Entropy [1], which presents that strength of password depends on character composition rather than length alone.

#### 4.2 Empirical Probability Estimation

Unlike the original Expectation Entropy formulation, which uses fixed alphabet probabilities, this implementation derives empirical probabilities directly from the password. For each character class  $i$ , a class-level probability is computed as:

$$p_i = \frac{n_i}{L}$$

This shows the actual distribution of characters within the password and captures predictable patterns common in human-chosen passwords.

To approximate per-symbol probabilities, the class probability is uniformly distributed across the size of the class:

$$p_{i,j} \approx \frac{p_i}{|\mathcal{C}_i|}$$

where  $|\mathcal{C}_i|$  is the size of the character class.

#### 4.3 Entropy Calculation (Shannon Entropy)

To produce an entropy value interpretable in terms of attacker effort, Shannon entropy is applied to the previously estimated symbol probabilities. The per-character entropy contribution is computed as:

$$H_{\text{char}} = - \sum_i p_i \log_2 \left( \frac{p_i}{|\mathcal{C}_i|} \right)$$

The total password entropy is then calculated by scaling the per-character entropy by the password length:

$$H = L \cdot H_{\text{char}}$$

The resulting value  $H$  is measured in bits and represents an effective entropy estimate that can be mapped to a password search space.

This formulation differs from Expectation Entropy, which defines a relative and unbounded diversity metric. The Shannon entropy-based approach used here ensures boundedness and enables attacker-centric interpretation.

#### 4.4 Offline Crack-Time Estimation

To translate entropy values into an interpretable security metric, the estimated entropy is mapped to offline brute-force cracking time using a standard attacker model:

$$\text{Time} = \frac{2^H}{\text{Guesses per Second}}$$

Two attacker models are considered:

- GPU scale attacker:  $10^9$  guesses per second
- Nation-state level attacker:  $10^{12}$  guesses per second

This step is not defined in the original Expectation Entropy paper and is introduced to provide attacker-centric feedback, in line with modern password security guidance.

## 5. Demonstration

The tool, programmed in C++, operates in an interactive mode. After entering a password, the user is shown:

- Estimated Expectation Entropy (in bits)
- Estimated offline cracking time under each attacker model

```
Enter a password to evaluate: Password

=== Results ===

Estimated entropy: 42 bits

Estimated offline brute-force crack time:
1) GPU-scale attacker (1e9 guesses/sec): 1 hours
2) Nation-state attacker (1e12 guesses/sec): 4 seconds
```

Figure 1

Figure 1 shows the output for a commonly chosen password. Despite satisfying minimal length requirements, the password exhibits low structural diversity and results in a low entropy estimate and an instant cracking time. This demonstrates the limitation of length-based or naïve entropy assumptions.

```
Enter a password to evaluate: dfs\@#fu42D

=== Results ===

Estimated entropy: 70 bits

Estimated offline brute-force crack time:
1) GPU-scale attacker (1e9 guesses/sec): 27135 years
2) Nation-state attacker (1e12 guesses/sec): 27 years
```

Figure 2

Figure 2 shows the output for a more diverse password containing a balanced mixture of character classes. In this case, the entropy estimate is significantly higher, leading to longer estimated cracking times. This highlights how character distribution and structure influence password strength beyond length alone.

The output is intended strictly for educational interpretation, not as a definitive security assessment.

## 6. Discussion

The formulation used in this work was based on the core idea behind Expectation Entropy translating into an interpretable attacker-centric form. Expectation Entropy highlights that password strength depends on how characters are distributed across classes, rather than assuming they are chosen uniformly at random. To apply this insight to crack-time estimation, we treated character class usage as an empirical probability distribution derived directly from the password and used Shannon entropy to quantify uncertainty in bits. This choice preserves the paper's main insight while producing a bounded entropy value that can be mapped to brute-force guessing effort. The formulation is therefore not taken directly from prior work but represents a logical adaptation of Expectation Entropy's concept to support attacker-centric interpretation.

## 7. Limitations

The limitations of this project include:

- Simplified entropy design
- No probabilistic language models
- No leaked password datasets
- Offline brute-force attacks only

The implemented methodology is intentionally simplified and designed for research purpose only.

## 8. Conclusion

This project implements an educational password strength estimation tool inspired by Expectation Entropy as proposed in [1]. By translating entropy values into estimated offline cracking time, it bridges the gap between theoretical password strength metrics and attacker-centric interpretation, aligning with recent trends in explainable security research.

## References

- [1] K. Reaz and G. Wunder, "Expectation entropy as a password strength metric," *arXiv preprint arXiv:2404.16853*, 2024.
- [2] P. G. Kelley, S. Komanduri, M. L. Mazurek, R. Shay, T. Vidas, L. Bauer, N. Christin, L. F. Cranor and J. Lopez, "Guess again (and again and again): Measuring password strength by simulating password-cracking algorithms," *2012 IEEE Symposium on Security and Privacy (SP)*, 2012.
- [3] P. A. Grassi, R. A. Perlner, E. M. Newton, A. R. Regenscheid, W. E. Burr, J. P. Richer, N. B. Lefkovitz, J. M. Danker, Y.-Y. Choong, K. K. Greene and M. F. Theofanos, "Digital Identity Guidelines: Authentication and Lifecycle Management," 2017.